FINAL SECURITY AND AUDIT SPECIFICATION

Project ID: SIH26034
Product: NyayaDrishti-LM
Governing Standard: Section 63 Bharatiya Sakshya Adhiniyam, 2023 (BSA 2023)
Status: FROZEN

---

1. Security Architecture & Threat Model

NyayaDrishti-LM operates as a regulatory enforcement support system. Security is designed around three non-negotiable principles:

1. **Chain of Custody:** Digital photographs and derived measurements must possess mathematical proof of zero tampering between capture and courtroom presentation.
2. **Role-Based Access Control (RBAC):** Strict separation of privileges between field inspectors, adjudicating controllers, and central policymakers.
3. **Local Encryption at Rest:** All offline inspection dossiers stored on field devices are encrypted to protect sensitive commercial intelligence.

---

2. Role-Based Access Control (RBAC) Matrix

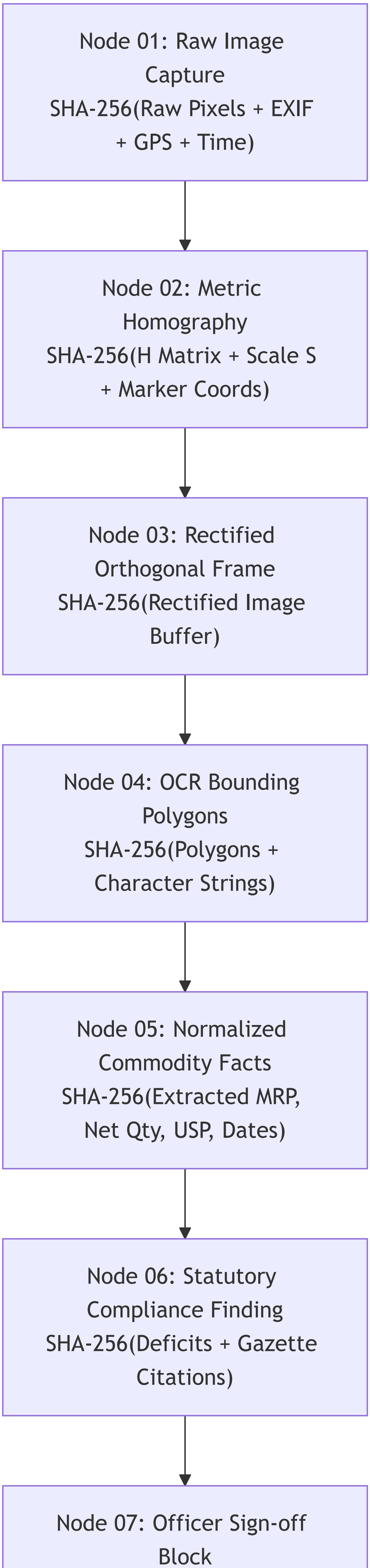
```
┌─────────────────────────────────────────────────────────────────
──────────┐
│                          ROLE-BASED ACCESS MATRIX
│
├───────────────────────────────────┬────────────────────────────────────┬────────────
──────────┤
│ ROLE                              │ PRIMARY PERMISSIONS                │ STATUTORY SCOPE
│
├───────────────────────────────────┼────────────────────────────────────┼────────────
──────────┤
│ 1. FIELD LMO (Inspector)          │ • Initiate new inspection          │ Restricted to
assigned circle    │
│                                   │ • Capture package facets           │ or district. Can
create draft    │
```

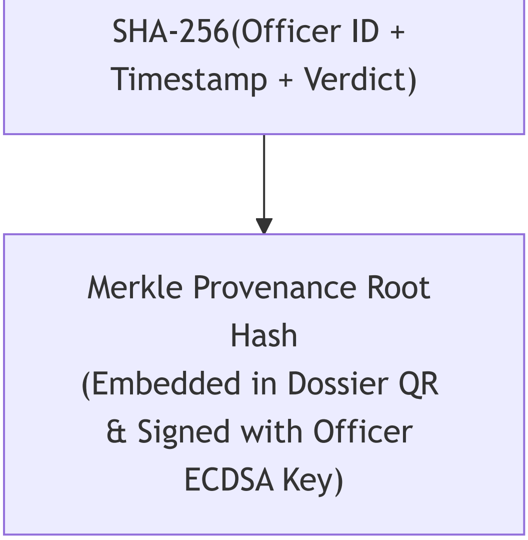
```
│                              │ • Review visual overlays      │ inspection memos
only.           │
│                              │ • Digitally sign draft memo   │ Cannot compound
or prosecute.    │
├──────────────────────────────┼───────────────────────────────┼──────────────────
────────────────┤
│ 2. ADJUDICATING CONTROLLER   │ • Review filed dossiers       │ Jurisdiction over
district/state.│
│   (Assistant/Deputy)         │ • Issue Section 36 notices    │ Statutory power
to execute       │
│                              │ • Record compounding fees     │ compounding and
formal orders.   │
│                              │ • Escalate to Magistrate      │
│
├──────────────────────────────┼───────────────────────────────┼──────────────────
────────────────┤
│ 3. CENTRAL DoCA ADMIN        │ • High-level national dashboard│ Read-only
analytical access.    │
│                              │ • Category non-compliance trends│ Zero access to
alter active    │
│                              │ • Offender registry search    │ field inspection
records.        │
├──────────────────────────────┼───────────────────────────────┼──────────────────
────────────────┤
│ 4. PRE-PRINT FMCG USER       │ • Upload packaging artwork PDF│ Sandboxed
evaluation only.       │
│   (Self-Screening Sandbox)   │ • Receive compliance scorecard│ Zero access to
enforcement logs. │
└──────────────────────────────┴───────────────────────────────┴──────────────────
────────────────┘
```

---

3. Section 63 BSA 2023 Cryptographic Provenance Architecture

Under Section 63 of the **Bharatiya Sakshya Adhiniyam, 2023** (which repealed and superseded Section 65B of the Indian Evidence Act, 1872 on 1 July 2024), electronic records are admissible as evidence provided their integrity, device provenance, and custodial chain are certified.


Node 01: Raw Image Capture
SHA-256(Raw Pixels + EXIF + GPS + Time)
Node 02: Metric Homography
SHA-256(H Matrix + Scale S + Marker Coords)
Node 03: Rectified Orthogonal Frame
SHA-256(Rectified Image Buffer)
Node 04: OCR Bounding Polygons
SHA-256(Polygons + Character Strings)
Node 05: Normalized Commodity Facts
SHA-256(Extracted MRP, Net Qty, USP, Dates)
Node 06: Statutory Compliance Finding
SHA-256(Deficits + Gazette Citations)
Node 07: Officer Sign-off Block



Cryptographic Sealing Protocol:

1. At the moment of shutter press, raw image bytes are hashed via **SHA-256**.
2. Device hardware ID, network atomic time (or certified local monotonic clock), and GPS coordinates are bound into `Node 01`.
3. Each pipeline transformation calculates its own SHA-256 hash using the parent node hash as salt, forming an immutable Directed Acyclic Graph (DAG).
4. The final Merkle Root is digitally signed using the officer's private key (ECDSA on curve `secp256k1` or Ed25519) and rendered as a high-density QR code on the header of the printed Inspection Memo.
5. In court, any defense claiming the photograph was photoshopped or text altered can be disproven by recalculating the Merkle tree from the raw stored capture.

---

4. Local Storage & Data Privacy Standards

- **Encryption at Rest:** Local SQLite databases containing field inspection dossiers are encrypted using **SQLCipher (AES-256-CBC)** with keys derived via PBKDF2 from the officer's login PIN.
- **Zero Cloud Leakage in Field:** No photos, metadata, or manufacturer details are transmitted over unencrypted public networks. Synchronization to central eMaap occurs exclusively over TLS 1.3 with mutual certificate pinning (mTLS) when authenticated on official government networks.
- **Audit Logging:** Every user interaction (inspection created, image recaptured, measurement overridden, notice issued) is appended to an immutable, write-only local audit log with monotonic sequence numbers.